

Where PAL Stands

What the assistant can now do safely, what was quietly broken before, and the four decisions that are yours rather than the engineering team's.

SAFETY CHECKS	URGENT ACTIONS	YOUR DECISIONS
250 automated	2	4

Two things to act on this week

Neither came from the new work. Both were already in the system and both carry regulatory exposure, so they sit above everything else in this document.

ACT NOW

Live passwords and API keys are stored in the code repository

The files holding PAL's secrets — the keys that pay for Google and Anthropic usage, the database password, and the key that signs patient login tokens — were saved into the code history. Anyone who has ever had a copy of the code has them, including former contractors and anyone a laptop was lost with.

What this means in practice: someone with those keys could run up AI charges on your account, read the database directly, or mint a login token for any patient.

What needs to happen: change every key, then have the team clean them out of the code history. Changing the keys is the urgent half — removing them from history matters, but a rotated key is already harmless.

ACT NOW

A copy of the patient database is in the code repository

A 735 KB database export sits in the code, containing patient records, phone numbers, email addresses, prescriptions, lab results and conversation history — around 35 people's contact details.

Why it matters commercially: under the DPDP Act this counts as a personal-data breach if the repository was ever reachable by anyone not entitled to that data. It is also the first thing a hospital's IT team or an investor's technical reviewer will look for, and finding it costs more trust than it costs to fix.

What needs to happen: the same history cleanup, and a rule that database exports never go near the code.

Things that were silently not working

These were found by running the system rather than reading it. Each one looked fine from outside, which is why they had survived.

WHAT WAS WRONG

WHAT A PATIENT WOULD HAVE SEEN

The assistant could not produce an answer at all. The final step that assembles the response had three faults and crashed every time.

An error, or nothing. The whole conversational feature was non-functional.

The assistant forgot the conversation. Each turn was being saved, but nothing was ever read back — so it read every question as if it were the first.

"What causes it?" answered as though "it" meant nothing. Exactly the problem the team had already tried to fix.

Booking requests were answered as questions. "Book a review with my doctor" had no path to the booking flow, so it fell through to the information paths.

A patient trying to book gets an explanation instead of an appointment.

A stroke described in plain words was treated as routine. The system only recognised the word "stroke", not "my face is drooping and I can't speak" — and an automated test was locking that behaviour in as correct.

Someone having a stroke gets a general health answer instead of "call an ambulance now".

"Can I switch from Glycomet to Glucophage?" was not treated as a prescription request. The system caught "which should I take" and "is X better than Y", but not the word *switch*.

A patient asking to change brands gets an answer about brands instead of being sent to their doctor — the one thing this product must never do.

Setting up a new server broke patient logins. A version mismatch meant password handling failed outright on a fresh install.

Nobody can register or log in. It would have looked like a server problem.

Medical research was not filtered to human studies. Results from animal and laboratory research were treated the same as human trials.

Advice shaped by a mouse study, presented with the same confidence as a clinical trial.

All seven are fixed, and each has an automated test so they cannot come back unnoticed.

What happens when someone asks a question

Worth reading once, because the order is the safety argument. Each step below can *end* the question. The AI is not consulted until step six.

STEP

WHAT IT DOES

WHEN IT ENDS THE QUESTION

1. Is this an emergency?

Reads the words for chest pain, stroke signs, severe bleeding, and for a mental-health crisis. No AI involved — a fixed list.

Urgent-care guidance, or crisis helplines and a person. Immediately.

2. Is this asking for a prescription?

"Which should I take", "is X better than Y", "can I switch to Y".

Referred to their doctor, and the question is carried onto their next appointment.

STEP	WHAT IT DOES	WHEN IT ENDS THE QUESTION
3. What is being asked, and about whom?	General health information, or something about this patient specifically.	If it genuinely could be either, it asks rather than guessing.
4. How much work does this need?	A fixed set of rules, not a judgement call.	Simple questions are answered on the phone itself — no server, no cost.
5. Should their records be used?	A consent check before any personal data leaves the database, recorded for audit.	If not permitted, it answers generally instead of failing.
6. Gather.	Medical research, the patient's own records, a medicine card, an appointment — whichever apply, at the same time.	—
7. Write the answer.	The AI writes it, and then the answer is <i>checked</i> : any sentence making a clinical claim must have a human study behind it. One chance to fix it, then the claim is removed.	—
8. Remember, selectively.	The conversation is saved so the next question has context. Refusals leave a marker but not their content.	—

The medicine lookup in step 6 is started early and collected at the end, so it runs alongside everything else rather than making the patient wait.

Three kinds of question, three kinds of source

The distinction the whole product rests on is not *where* an answer came from but *what that source is allowed to be used to say*.

- **A clinical question** — “does this work?” — goes to published medical research, restricted to studies done in humans and published in 2000 or later. Only this can back a statement about whether something works, at what dose, or with what risk.
- **A named medicine** — “what is Glycomet 500?” — goes to the pharmacy listings, and comes back as a card. It can say what the label says. It can never be used as evidence in the written answer.
- **The patient’s own data** — “what was my last reading?” — comes from their records, behind the consent check, and is used for them alone.

A journal name is not enough on its own, which is the non-obvious part: the New England Journal and Nature publish animal studies constantly. The system checks each individual study’s own record for whether it was done in humans, rather than trusting the journal it appeared in.

What the assistant will and will not do now

It refuses, deliberately, in three different ways

These are separated on purpose, because they need different screens. Sending a patient in crisis to a booking calendar is its own kind of failure.

- **A possible emergency** — chest pain, stroke signs, severe bleeding — gets urgent-care guidance immediately. No research, no booking, no waiting for the AI to decide.
- **A mental-health crisis** gets crisis helplines and a person to talk to. Never an appointment slot.
- **"Which medicine should I take?"** is referred to their doctor — and the question is carried forward onto their next appointment, so it becomes something the consultation improves rather than a dead end.

All three happen before the AI is consulted at all. A refusal that depends on the AI choosing to refuse is not a refusal.

It describes medicines, and never recommends them — and this now works

If a patient types a brand name, they get a card: the compound, strength, form, manufacturer, what the label says it is for, common side effects, and whether it is prescription-only — with a standing line that this is information, not advice, and to ask their doctor. Much like a Google health panel. This was designed earlier but could not run; it runs now, against the live 1mg and PharmEasy listings.

It runs one way only. A patient can ask "*what is Glycomet 500?*". Nothing can turn "*what should I take for diabetes?*" into a brand name — the system only ever looks up a name the patient typed themselves, and discards any word introduced by the word *for*, because that names a condition rather than a medicine.

It will not show a different medicine under the name the patient asked about.

This needed building deliberately: both pharmacies answer a search for "Glycomet" with rival products — a different molecule from a different manufacturer — ranked as if they were the same thing. Showing one of those on a card headed "Glycomet" would be a brand substitution made by the software. The system refuses any listing whose name or strength does not match what the patient wrote: *Glycomet 500* will not resolve to *Glycomet GP 1*, which is a different composition at a different dose.

If a pharmacy is slow, blocked or redesigned, the patient still gets their answer — without a card, and without an error. The lookup also runs alongside the rest of the work rather than in front of it, so it does not make the assistant feel slower.

Clinical claims must cite human research

A statement about whether something works, at what dose, or with what risk, can only rest on a human study. A pharmacy listing can support a price or a pack size and nothing more. This is checked *after* the answer is written, not merely requested beforehand — an instruction to an AI is not a guarantee.

What a deliberate attempt to break it found

Before calling any of this finished, the new code was attacked rather than reviewed — every problem below was reproduced by running it. Ten were found. All are fixed, and each now has a test named after the problem so it cannot return quietly.

Three of them were in things the previous version of this document had already told you were working. That is the honest reason this section exists.

The tenth was found a different way: by sitting down and having a patient's conversation with it — eleven turns, a diagnosis question, three brand names, the three questions it must refuse, and an emergency. Reading code and using it are not the same test.

FOUND AND FIXED **A patient could have been shown the wrong medicine under the right name**

Asked about **Glycomet**, the system could return the card for **Glycomet GP** — and did, because the pharmacy ranks GP first and the matching rule only compared the first word.

These are not variants. Glycomet is metformin. Glycomet GP adds a second drug that lowers blood sugar hard enough to cause a hypoglycaemic episode. The same held for Ecosprin 75 against Ecosprin AV, and Pan 40 against Pan D.

The rule is now symmetric: a listing must carry every part of the name the patient typed, and no part they did not. Fourteen real brand pairs are pinned in tests.

FOUND AND FIXED **The date shown on a study was not its publication date**

Medical records at the National Library of Medicine carry several dates — when the paper was published, when it was catalogued, when the entry was last revised. The code was reading the wrong one.

A paper from 1997, revised in 2021, was being shown as 2021 — and the 2000 cut-off you asked for let it through, because the check was looking at the revision date. On a live sample, more than a third of results carried a year that was not their publication year.

Worth noting where this was caught: in the act of proving the cut-off worked. The cut-off *did* work; the label on the result did not.

FOUND AND FIXED **A patient's condition was being sent to a pharmacy website**

Asked "what is the medicine for the treatment of hypertension", the system sent the word *hypertension* to a commercial pharmacy in a web address. The rule that a condition must never be looked up was there; it was checking too short a window of text to see the phrase.

Two problems in one: the system was working backwards from a condition to a brand, which is the thing it is built not to do, and a patient's health information was leaving to a third party who had no business receiving it.

FOUND AND FIXED**One bad page could freeze the whole service**

A pharmacy page built in a particular way took 26 seconds of processing — and while it ran, every other patient's request waited. A large enough page never finished at all. It now takes under a thousandth of a second.

There was also a way for a pharmacy page to redirect the system into making requests to machines inside our own network. Closed.

FOUND AND FIXED**The safety check was blocking the medicine cards it was built to allow**

The rule is that a pharmacy listing can be *shown* but never used as medical evidence. In practice the check could not tell the two apart: the sentence “Glycomet 500 contains metformin hydrochloride 500mg” was rejected, because it contains a number followed by “mg”.

A composition is not a medical finding. It is what is printed on the strip. Left as it was, the assistant could never state the contents of the card it was showing — on every medicine question, for every patient. The distinction the whole product rests on would have collapsed the first time someone asked about a medicine, and no test caught it because every test asked what the check *rejects*.

The exception added is deliberately narrow, and what it still refuses is the point: “take 500mg twice daily”, “contains 500mg and lowers HbA1c by 1%”, and “contains 500mg and is safe in pregnancy” are all still blocked.

Five smaller problems were fixed alongside: adverts and “similar product” links leaking onto cards as the medicine's strength, small print appearing as the manufacturer, a greeting like “Hello sir” using up the lookup so the medicine named afterwards was never checked, the research service failing in a way that read as “no evidence exists”, and medicine names typed in Hindi numerals never matching.

What it did not find, having tried hard: no way past the approved-sources list, and no way to get a pharmacy listing accepted as medical evidence. The rule that a pharmacy can be shown but never cited held everywhere it was attacked.

Four decisions that are yours

DECISION Where the medicine data comes from

The system reads brand information from 1mg and PharmEasy, as you asked, and it is working. Two things do not change by building it that way, and both are worth saying plainly a third time: **it is against those sites' terms of use**, and it breaks whenever they redesign their pages. The second already showed itself during this work — one of the two search pages had been rebuilt since it was last looked at, and the obvious way of reading it returned nothing at all.

The alternative is NPPA's government price list, which is free, public, and carries brand, composition, strength, manufacturer and price. It covers scheduled medicines rather than everything. The code is built so either can be swapped in without rework.

Worth a lawyer's read before this ships to patients.

DECISION Whether patient data may reach an outside AI

Today the research side and the patient-records side are separate systems, so records never reach an outside AI. That is easy to demonstrate to a regulator — and it is rigid: no single answer can combine a patient's own readings with the research about them, which is most of what a personalised health assistant is for.

Merging them is the better product and a harder compliance story. The mechanism to do it safely is built; switching it on is your call.

DECISION A clinician needs to review one list

The system decides which sentences count as "clinical claims" needing research backing. That is a judgement about medical language, not about software. It is now printed as a plain table — no technical knowledge needed — with the question on each row: *is this right, and what is missing?*

Building that table immediately caught one gap the engineers had missed, which is the argument for having a clinician look at the rest.

DECISION Whether to finish the Perplexica work

Worth saying plainly: **Perplexica is not connected to PAL.** What was built is the safety and evidence rules, written directly into PAL. The research engine itself was not.

This is smaller than it was. Two of the three routes no longer need it: medical research (PubMed) and the medicine cards both now work, because each talks to its source directly rather than through a general search engine.

What is still missing is searching journal websites — NEJM, BMJ, Nature, Medscape, bioRxiv are listed as approved sources with nothing able to reach them. That needs one small connecting component, roughly a day's work. The larger question of the full research engine can wait behind it.

How much of this is proven

250 automated checks run in about a second and cover every rule described here. They need no internet and no database, which matters: checks that are awkward to run stop being run.

The medical research filter is now proven against the live PubMed service. This was the one outstanding item. Tested end to end: the filter narrows results correctly at every step, and — the test that actually matters — every article it returned was genuinely human research, checked against PubMed's own subject tagging. On a topic chosen because it is dominated by laboratory and animal work, the unfiltered search returned studies in mice and rats; the filtered search returned none.

The 2000 cut-off is proven the same way. You asked for nothing older than the year 2000, and it is worth saying why that is not just tidiness: a 1974 paper quoted next to a 2023 one reads as equally current to a patient, and the older one may predate the drug they are actually taking. Checked live on a topic chosen because it has a lot of 1990s literature — without the cut-off, five of twenty results were from the 1990s, the oldest 1993; with it, none. And the count arithmetic is exact: 605 studies from 2000 onwards plus 5 before it equals the 610 total.

It is enforced in two places, not one. The date range is asked for when searching, and then checked again on each study that comes back. If the first ever stopped working — a change at their end, not ours — the second still holds. A study whose date cannot be read at all is discarded rather than assumed recent.

Proving it led to a better design. Previously the system trusted the search: "this came back from a human-only search, so it is human research." It now checks each individual study's own record. If the filter ever broke, an animal study would be automatically demoted and could no longer support a clinical statement — instead of being quietly presented as human evidence. The failure mode changed from *silent and dangerous* to *safe by default*.

Three safeguards now sit on this: a one-command check your team can run, an automatic check when the system starts, and the per-study verification above on every answer.

Setting the research connection up is now one command. `python`

`scripts/pubmed_setup.py --check` prints what is configured, where each value came from, and then makes one real request to confirm it works. Nothing has to be configured for it to run — the defaults are a working connection. Two things are worth adding: a contact email, which the US National Library of Medicine asks for so they contact you before cutting you off, and a free access key that raises the request limit. Neither costs anything.

One thing was quietly wrong here and is now fixed: PAL had settings for that contact email and for identifying itself, and never actually sent either. From the outside it looked configured.

For your developer, deployment is unchanged: copy the example settings file, start the containers. Every new option has a working default and is documented in that file with what it does, so nobody has to read the code to configure it. Three commands confirm it is working — one for the research connection, one for the medicine lookup, and one that replays a whole patient conversation and prints what the system did at each step.

Nothing has been published or deployed. The work is a package your team applies when they choose. The technical detail behind every point here is in the Developer Guide.